Contents

MobiDesk — Product Requirements Document **2**
1. Product summary . . . 2
1.1 Product differentiator . . . 2
1.2 R1 outcome . . . 2
1.3 Completion definition . . . 3
2. Problem and users . . . 3
2.1 Problem . . . 3
2.2 Primary user — Student . . . 3
2.3 Secondary user — Project/lab administrator . . . 3
2.4 System actors . . . 4
3. Product principles and requirement language . . . 4
3.1 Non-negotiable principles . . . 4
3.2 Normative terms . . . 4
4. Release scope . . . 5
4.1 R1 — Secure Mobile Cloud PC . . . 5
4.2 R2 — Authenticated Dock / External Monitor . . . 6
5. User journeys and observable states . . . 6
5.1 Student journey . . . 6
5.2 VM lifecycle and transport readiness . . . 7
5.3 Connection state machine . . . 7
6. Product architecture decisions . . . 8
6.1 Android application boundary . . . 8
6.2 Control plane and session plane . . . 8
6.3 Session grant contract . . . 9
6.4 Windows guest authentication . . . 9
6.5 Broker readiness . . . 10
6.6 Local FreeRDP-to-WSS transport . . . 10
6.7 RDP server certificate . . . 11
6.8 Session rendering and R2 surface readiness . . . 11
7. Functional requirements . . . 12
Authentication and identity . . . 12
VM assignment and readiness . . . 12
Session authorization and relay . . . 12
Windows guest authentication . . . 13
Native RDP client and rendering . . . 13
Touch, pointer and keyboard input . . . 13
Lifecycle and cleanup . . . 14
Telemetry and diagnostics . . . 14
Device and application security . . . 14
Release integrity . . . 14
Dock pairing and display (R2) . . . 15
8. Non-functional requirements and pilot performance gates . . . 15
8.1 Reference device and platform baseline . . . 16
8.2 Background behavior . . . 17

9. Privacy, security and trust requirements 17
10. VM, identity and data lifecycle 18
11. Product success measures 19
12. User-facing error catalogue 19
13. Release gates 20
14. Ownership and dates 21
15. Risks 21
16. Normative references 22
17. Change control 23

MobiDesk — Product Requirements Document

Version: 1.2
Date: 3 November 2026
Status: Owner review draft — architecture decisions recommended and closed in this revision; owner approval still required
Repository: `master43721/mobidesk-android`
Primary deliverable: A tested, owner-signed Android application that opens the correct assigned Windows Cloud PC through the secured session broker.

---

1. Product summary

MobiDesk is a campus-controlled thin-client experience. A student signs in with their college identity, sees the one Cloud PC assigned to them, and opens that Windows desktop on an Android phone. The VM performs the computing work; the phone supplies identity, session controls, display, touch and keyboard interaction. A later release extends the same product to a compatible external monitor through a phone-to-dock workflow.

MobiDesk is not a VM hypervisor, a general-purpose VPN, a public RDP port forwarder, or a Guacamole administration console. It must not let a student choose a VM, hostname, IP address or port.

1.1 Product differentiator

R1 provides a controlled campus Cloud PC experience using the college's identity and assignment rules, with no direct public RDP exposure. R2 adds the phone-to-monitor dock experience. The dock is a strategic differentiator and remains in the product roadmap; it is not allowed to make R1's mobile session an unfinished conditional feature.

1.2 R1 outcome

A student with exactly one valid assignment and an available Windows VM can:

1. Sign in using the existing MobiDesk/Supabase authentication flow.
2. See their assigned Cloud PC and a truthful, recently measured connection status.
3. Tap Connect and enter the separate Windows lab credentials.
4. Open the assigned Windows desktop through a one-time broker grant and WSS relay using the pinned native FreeRDP engine.
5. Use touch, pointer, keyboard and modifier shortcuts.
6. Disconnect or recover from a supported network interruption without leaving an orphaned session, socket, native thread or secret.

1.3 Completion definition

R1 is complete only when the exact release candidate, on a physical Android device, opens the correct assigned Windows VM through the deployed secured broker; positive and negative authorization tests pass; measured performance meets the R1 gate; and the exact tested APK is signed with the approved release key and its hash/certificate/source revision are recorded.

A successful compile, a debug APK, FreeRDP libraries packaged in an APK, broker unit tests, a mock desktop, or a working Guacamole WebView is not proof of R1 completion.

2. Problem and users

2.1 Problem

Students need a consistent desktop environment for lab work but should not need to understand VM addresses, VPN configuration, RDP ports, gateway settings or hypervisor operations. The institution needs to retain control over identity, assignment and access policy while keeping guest machines off the public Internet.

2.2 Primary user — Student

A student uses the college-provisioned account, sees only their own Cloud PC, connects, works and disconnects. They cannot browse the VM pool, edit assignment data, choose a target host, start/stop arbitrary VMs, or obtain another student's session.

2.3 Secondary user — Project/lab administrator

The administrator provisions student accounts, maintains assignments, provisions the separate Windows guest account, checks VM and broker health, and handles reset/restore requests through approved out-of-band tools. R1 does not include an Android administrator console.

2.4 System actors

- **Supabase Auth and Postgres/RLS:** identity, student profile and assignment records.
- **MobiDesk session broker:** authenticates the caller, resolves the assigned VM, checks session state, issues one-time grants, relays RDP bytes and emits audit/diagnostic events.
- **KVM/libvirt host and Windows guests:** lifecycle state, private VM network and RDP service.
- **Android FreeRDP client:** NLA, RDP certificate validation, desktop rendering and input.
- **Future dock:** a paired, authenticated display/input endpoint; USB/AOA identification alone is not trust.

3. Product principles and requirement language

3.1 Non-negotiable principles

1. The server derives the user's identity and VM assignment. The client never selects the network destination.
2. No inbound public TCP/3389. The broker is the only authorized path from the application to a guest RDP service.
3. Supabase credentials and Windows credentials are separate. A Supabase password is never reused for Windows.
4. No fake/mock/demo VM is ever shown as if it were the student's real assigned Cloud PC in a production build.
5. A state label must describe a measured condition, not an assumption. `RUNNING` does not mean `RDP_READY`; RDP reachability does not mean the Windows user's NLA login succeeded.
6. Product requirements outrank current prototype behavior. Code changes must satisfy the approved PRD or trigger a documented change request.
7. Fail closed for missing, duplicate, stale, revoked or ambiguous identity/assignment/session data.

3.2 Normative terms

- **MUST / MUST NOT:** release requirement.
- **SHOULD / SHOULD NOT:** expected unless a documented reason is approved.
- **MAY:** optional behavior.

Every MUST requirement has a verification method in `TEST_PLAN.md` or an explicit release-evidence item.

4. Release scope

4.1 R1 — Secure Mobile Cloud PC

In scope

- Preserve the existing native Kotlin/Jetpack Compose sign-in, account/session recovery and student workspace behavior.
- Read the authenticated student's own profile and exactly one current VM assignment through RLS-protected queries.
- Query live VM lifecycle and RDP transport readiness through the broker, not through a guessed Supabase status column.
- Request a short-lived, single-use broker grant without sending a VM ID, hostname, IP address or port in the grant request.
- Establish a WSS binary relay to the broker and a protected local transport into the pinned FreeRDP v3.32.0 Android client.
- Use a MobiDesk-owned native RDP session Activity and native session controls. Flutter/MethodChannel components are not part of this repository or design.
- Prompt for a separate Windows guest username/domain/password before grant/tunnel setup. Keep credentials in volatile memory only.
- Validate the RDP server certificate using broker-delivered approved fingerprint metadata or a specifically approved internal CA. Certificate errors fail closed.
- NLA, RDP display, touch/pointer, keyboard, modifier keys, orientation, disconnect, bounded reconnect and safe error messages.
- Security logging and performance telemetry with no tokens, guest credentials, screen contents or routable VM endpoints.
- Automated tests, physical-device R1 verification and owner-signed release packaging.

Out of scope for R1

- Multiple VMs per student, user-selected VM, arbitrary host/IP/port input.
- Linux guest desktops; the pilot is Windows-only.
- Student-controlled VM start/stop, snapshot, reset or provisioning.
- Windows SSO, password handoff from the broker, Supabase-to-Windows password reuse, automatic password rotation, or domain join.
- Clipboard/file transfer, audio redirection and remote USB passthrough unless separately threat-modelled and approved.
- Android administrator UI and role inference from email address.
- Dock-mode monitor rendering and reverse-input release behavior. R1 must keep an output abstraction suitable for R2 but does not claim R2 completion.
- Unbounded multi-user capacity or automatic shared-RAM scheduling.

4.2 R2 — Authenticated Dock / External Monitor

R2 includes compatible-phone and Raspberry Pi 4B dock pairing, display capability exchange, monitor output, keyboard/mouse reverse input, reconnect and display-resolution management. R2 must begin with a measured architecture spike comparing:

1. Pi-hosted/native FreeRDP, where the dock receives the authorized session and renders the desktop itself; and
2. Phone-rendered RDP plus phone-side H.264 encode and Pi-side decode.

The second path incurs decode/render/encode/decode work and must not be chosen by default. AOA strings are discovery metadata only and are not proof of dock identity. R2 requires explicit user confirmation and cryptographic challenge-response with a key provisioned during dock pairing.

R1 must decouple session lifecycle from the display target and must verify the pinned FreeRDP build's display-update capabilities before the R1 architecture is frozen. R2 preserves the student's assignment and Windows guest as the target, but it does **not** promise to preserve the same broker grant, WSS connection or in-memory RDP transport. If seamless surface migration and `MS-RDPEDISP` resizing are proven, R2 may move the active RDP context to the dock. Otherwise, after explicit user confirmation, R2 may close the phone transport and obtain a fresh grant to reconnect to the same assigned VM. Reuse of the same Windows logon/session depends on the guest's Windows policy and must be verified; it is not guaranteed by MobiDesk. No UI or marketing text may call a reconnect the same live RDP transport.

5. User journeys and observable states

5.1 Student journey

1. **Sign in:** existing MobiDesk/Supabase authentication. Invalid/expired identity returns to sign-in; local logout clears local session state and closes an active desktop session.
2. **Load workspace:** obtain the profile and the student's assignment. Exactly one row is valid. Zero rows show `No Cloud PC assigned`; more than one row or malformed data show a safe assignment error and block Connect.
3. **Check status:** the app calls the authenticated broker status endpoint. Show lifecycle and transport readiness separately, including sample time. Never present old data as current.
4. **Connect:** only enable Connect when the most recent status sample is fresh and the broker reports `RUNNING` plus `RDP_NEGOTIATION_OK`. The grant request always rechecks the current assignment and readiness server-side.
5. **Guest authentication:** the native RDP session UI prompts for Windows username/domain/password. The UI explicitly states that this is

the Windows lab account, not the college sign-in password. Password persistence is not offered.

6. **Authorize and connect:** native session coordinator requests the grant, opens WSS and starts FreeRDP. NLA happens inside the RDP handshake. The RDP certificate must match the trusted pin/CA.
7. **Work:** native session Activity owns the rendering surface/view and controls. The Compose UI is not used as a remote-frame renderer.
8. **Disconnect:** immediately block input, close FreeRDP, close WSS and local transport, revoke/best-effort close broker session, clear temporary credentials and return to dashboard.

5.2 VM lifecycle and transport readiness

The UI MUST show two separate dimensions:

Dimension	States	What it proves
Lifecycle	`STOPPED`, `STARTING`, `RUNNING`, `STOPPING`, `ERROR`, `UNKNOWN`	Host/provider lifecycle observation only.
RDP transport	`NOT_CHECKED`, `TCP_UNREACHABLE`, `TCP_REACHABLE`, `RDP_NEGOTIATION_OK`, `UNKNOWN`	A broker-side private network check. `RDP_NEGOTIATION_OK` is not proof that the student's Windows credentials will pass NLA.

The broker performs lifecycle and private-network/RDP-negotiation checks. Supabase is not responsible for polling libvirt or TCP/3389. The initial status sample becomes stale after 15 seconds; Connect always causes a fresh broker-side authorization/readiness check.

5.3 Connection state machine

```
IDLE -> CHECKING_STATUS -> PROMPTING_GUEST_CREDENTIALS -> REQUESTING_GRANT
-> OPENING_WSS -> STARTING_LOCAL_TRANSPORT -> NEGOTIATING_RDP_NLA
-> CONNECTED
```

From any in-progress state, the flow may enter `FAILED(reason)` and must clean up before returning to `IDLE`. While connected, network loss enters `RECONNECTING`; retries use a new grant and revalidate the assignment. Expired or replayed grants are never reused.

`PROMPTING_GUEST_CREDENTIALS` is mandatory. The password stays in volatile native memory; it is not put in an Intent, URI, saved state, preferences, database, crash report or log.

6. Product architecture decisions

6.1 Android application boundary

The target repository is a native Kotlin/Jetpack Compose Android application. The UI boundary is locked for R1:

- **Compose UI / ViewModel:** sign-in, workspace, assignment card, status, user actions and safe error states.
- **Student/assignment repository:** Supabase Auth session and RLS-filtered profile/assignment reads.
- **Broker API client:** status and grant HTTPS calls with the current user's access token.
- **Session coordinator:** owns the Windows credential prompt, grant lifecycle, WSS relay, protected local transport, cancellation and cleanup.
- **MobiDesk `RdpSessionActivity`:** a dedicated full-screen native Android Activity owns the active remote desktop window. It hosts a `SurfaceView` (or the exact equivalent required by the pinned FreeRDP Android view API) as the render target and an Android-native overlay for keyboard, pointer and modifier controls. The selected Activity boundary is not a Flutter `PlatformView` and does not move remote frames through a Flutter texture pipeline.
- **Pinned FreeRDP Android client:** RDP protocol, TLS/NLA, rendering callbacks and input. The repository currently records v3.32.0, but that is a baseline fact, not a permanent security exemption. Before R1 release, review the exact gitlink against upstream security advisories and available patched stable releases; upgrade through a reviewed compatibility change if the pinned revision is affected. The implementer MUST inspect the checked-in pinned source and prove how its Android client accepts a render surface, credentials, certificate callback and raw-stream transport. Do not assume FreeRDP RD Gateway WebSocket mode speaks MobiDesk's custom raw-RDP WSS contract. Do not guess Intent extras or copy methods from upstream `master`.

The Compose dashboard launches `RdpSessionActivity` through an explicit, non-exported in-app entry point. The activity owns session lifetime and surface attach/detach. The floating toolbar is native Android UI layered above the FreeRDP surface; session state is owned by the session coordinator, not by a composable's transient state. No Flutter `MainActivity`, Flutter `MethodChannel`, `PhoneCloudPcActivity` or files from another repository are part of this product architecture.

6.2 Control plane and session plane

- **Control plane:** HTTPS; identity, assignment, lifecycle/readiness status, grant issuance, revocation and audit.
- **Session plane:** WSS binary frames from Android to broker; broker forwards bytes to the single server-side allowlisted private Windows endpoint

on TCP/3389.

- **Guest protocol:** RDP/TLS/NLA is end-to-end between FreeRDP and the Windows guest through the byte relay. The broker does not decrypt or terminate the RDP guest-authentication flow.
- **Infrastructure:** current lab evidence describes self-hosted KVM/QEMU/libvirt Windows guests on `mobilab-server`. Whether this remains the production hosting topology is an operational decision; all guest endpoints remain private.

6.3 Session grant contract

The target contract is specified in `API_CONTRACT.md`. `POST /v1/session-grants` accepts the authenticated caller's Supabase JWT and an empty body. It does not accept a VM ID or any target endpoint. The broker obtains the identity from the verified token, queries exactly one current RLS-visible assignment, resolves the VM UUID through its server-only allowlist, checks readiness, and issues a random one-use 60-second grant.

The broker API contract in `API_CONTRACT.md` is the implementation target. Prototype code is evidence of current progress only and does not define product behavior. Any implementation that accepts client-selected VM identity or routes to an endpoint outside the approved server-side allowlist is non-conforming. The dated prototype state and known implementation gaps are recorded separately in `BASELINE_AUDIT.md` and `PROGRESS.md`.

6.4 Windows guest authentication

R1 pilot decision: students enter a separately provisioned Windows lab username/domain/password in a native secure prompt for each connection. The prompt is a mandatory state in the connection flow and appears before grant issuance/WSS setup. It may be implemented in the native `RdpSessionActivity` or its native session coordinator; it MUST NOT be hidden behind a missing FreeRDP callback or left as a future integration detail.

The broker does not deliver guest credentials. The app never reuses Supabase credentials and does not save Windows credentials. The username/domain/password must not be placed in an Android Intent, URI, `Bundle`, saved state, `SavedStateHandle`, preferences, database, crash report or log. Hold the password in a short-lived mutable buffer where the selected FreeRDP API permits it; if an upstream API requires an immutable Java `String`, document that limitation, minimize its lifetime and clear all app-owned mutable copies after the native client has copied the credential. Clear credential state on NLA completion/failure and on every teardown path.

Each pilot VM must have a separately provisioned, least-privileged Windows lab account with only the rights required for that student's lab work and RDP access. College/lab administration owns account provisioning, reset, expiry and semester-end disablement. Wrong credentials produce a safe authentication

error; the broker grant is closed and a retry obtains a fresh grant. The simplest separate-password prompt is the pilot default because the current broker only relays RDP and has no Windows SSO/password-rotation function.

Options intentionally deferred:

- **Ephemeral password rotation through QEMU Guest Agent:** technically investigable, but it adds a privileged guest-agent execution path, password rotation service, recovery semantics and secret-delivery requirements. It is not the R1 pilot default.
- **Directory-joined/central identity:** potentially improves lifecycle and SSO, but requires domain infrastructure and an identity integration design. It is not assumed to exist.

6.5 Broker readiness

R1 adds `GET /v1/vm-status` to the broker contract. The app does not pass a VM ID, user-selected VM name or endpoint. The broker resolves the caller's unique assignment, reads lifecycle state through its approved host-side interface and performs a bounded private TCP/RDP negotiation check with a maximum 1,500 ms probe budget per request. It returns lifecycle state, RDP transport state, sample timestamp and probe duration. Do not claim `NLA_READY`, `DESKTOP_READY` or authenticated-user readiness before a Windows-user NLA login actually succeeds. A broker timeout or host-source outage returns `UNKNOWN`; it must never be translated into `RUNNING` or a cached healthy state.

The broker must validate the JWT's `session_id` against active Supabase session state for grant issuance and active relays. This check is performed only server-side using a protected, narrowly scoped database/access path. No service-role key or database credential may be included in the APK. If the selected Supabase access mechanism cannot safely query the session record, the broker design must provide a reviewed server-side revocation adapter before G2; it must not silently omit the check.

6.6 Local FreeRDP-to-WSS transport

The bridge MUST be process/session-owned, bounded and resistant to another local app claiming the transport. Preferred order is:

1. A socketpair or equivalent connected-descriptor integration if the pinned FreeRDP Android core can safely accept it.
2. An app-private Unix-domain socket with peer-UID verification if the pinned integration supports it.
3. A loopback TCP fallback only after a specific security design and proof. A random port alone is not sufficient because other local apps can scan local ports. The fallback must have a high-entropy one-time handshake secret unavailable to other UIDs, accept exactly one connection within

a short deadline, close the listener immediately, and pass a same-device malicious-app hijack test.

The adapter MUST preserve TCP byte-stream order across WSS binary message boundaries, bound both directions' queues, apply backpressure, and handle EOF, cancellation, timeout, half-close and broker restart. The MobiDesk `/v1/rdp` endpoint is a custom WebSocket carrying raw RDP byte-stream data; it is **not** a Microsoft RD Gateway (`MS-TSGU`) endpoint. Do not assume FreeRDP's RD Gateway/WebSocket transport can connect directly to this raw relay. The pinned FreeRDP code path MUST be inspected to prove the actual transport semantics. Use the protected local bridge unless a reviewed custom FreeRDP transport injection is implemented and tested against the raw-byte contract. If the pinned FreeRDP client cannot support a suitably protected transport, stop and resolve the integration rather than shipping an unauthenticated local listener.

6.7 RDP server certificate

The broker grant includes the approved SHA-256 fingerprint of the assigned VM's RDP server certificate (or an approved internal CA trust reference). This certificate is validated by the FreeRDP client at the guest-facing RDP TLS handshake; the broker is a byte relay and does not replace that validation. FreeRDP MUST validate the certificate against the per-VM policy. The release build must never enable an `accept all certificates` preference or a trust-all callback. Missing pin, mismatch, untrusted CA or unexpected certificate rotation fails closed and is an auditable error. Lab operations must document how the pin is created, verified, rotated and rolled back.

6.8 Session rendering and R2 surface readiness

R1's `RdpSessionActivity` separates session coordination from the display target. The FreeRDP render adapter targets a `RdpRenderTarget` contract rather than referencing dashboard/composable state. The contract owns surface attach/detach, viewport size, negotiated remote resolution, frame delivery and cleanup. It must not assume that a FreeRDP C context can be moved between Android surfaces.

Before the R1 native renderer is considered architecturally complete, the team MUST run a pinned-v3.32.0 spike that records (a) whether `MS-RDPEDISP` / `disp` is compiled and enabled, (b) whether FreeRDP can request a resolution change after connect, (c) whether its rendering callback can detach and reattach to a new Android surface without destroying the context, and (d) whether the session survives rotation and replacement of the render surface. The spike is an R1 architecture gate and a prerequisite to R2; it is not a claim that dynamic dock migration already works. If hot surface migration is unsupported, record the limitation and test the explicit R2 reconnect-to-the-same-assigned-VM fallback, including the Windows logon/session behavior. R1 does not promise a seamless

phone-to-monitor hot switch.

7. Functional requirements

Priority values are `MUST` for R1 release blockers, `SHOULD` for R1 quality requirements, and `R2` for dock-release requirements.

Authentication and identity

- **FR-AUTH-01 — MUST.** Preserve existing Supabase sign-in, session restoration, password recovery and sign-out behavior.
  - *Acceptance:* Baseline regression suite passes against the frozen source revision.
- **FR-AUTH-02 — MUST.** All profile and assignment queries use the current authenticated user token and RLS.
  - *Acceptance:* RLS tests prove one user cannot read another student's records.

VM assignment and readiness

- **FR-VM-01 — MUST.** The app shows exactly one assigned Windows VM or a clear no-assignment/error state.
  - *Acceptance:* Zero, one, duplicate and malformed assignment tests.
- **FR-VM-02 — MUST.** The grant request contains no `vm_id`, hostname, IP address or port.
  - *Acceptance:* Broker contract test and captured request inspection.
- **FR-VM-03 — MUST.** The broker resolves the authenticated user's assignment and private endpoint server-side; missing/duplicate/unmapped assignment fails closed.
  - *Acceptance:* Cross-user and tampering tests; unmapped VM denied.
- **FR-VM-04 — MUST.** The broker returns lifecycle and RDP transport readiness separately through `/v1/vm-status`.
  - *Acceptance:* Status API integration tests and stale-state UI tests.
- **FR-VM-05 — MUST.** A status sample older than 15 seconds is stale; Connect triggers a fresh status/authorization check.
  - *Acceptance:* Clock-controlled tests.

Session authorization and relay

- **FR-SES-01 — MUST.** Grant is random, one-use, bound to user/session/assignment/target, and expires within 60 seconds.
  - *Acceptance:* Expiry, replay, cross-user and concurrency tests.
- **FR-SES-02 — MUST.** WSS carries binary RDP bytes only; grant is supplied in an Authorization header, never a query string.
  - *Acceptance:* WebSocket contract test and log scan.

- **FR-SES-03 — MUST.** Broker rechecks the active assignment at relay open and during the active session. Revocation takes effect within 30 seconds.
  - *Acceptance:* Revoke assignment/session during an open relay and measure termination time.
- **FR-SES-04 — MUST.** Enforce one active RDP session per student and a bounded pilot-wide concurrent-session limit.
  - *Acceptance:* Parallel-session and slot-cleanup tests.

Windows guest authentication

- **FR-GUEST-01 — MUST.** Prompt for separate Windows credentials before starting the broker grant flow.
  - *Acceptance:* UI flow tests; no credentials included in grant API.
- **FR-GUEST-02 — MUST.** Do not store or log Windows username/password; clear transient buffers after the native client has safely copied them and on teardown.
  - *Acceptance:* Storage scan, log scan and memory-lifecycle review.

Native RDP client and rendering

- **FR-RDP-01 — MUST.** Use pinned FreeRDP v3.32.0 and complete Windows NLA.
  - *Acceptance:* Physical device reaches assigned Windows sign-in/desktop with approved credentials.
- **FR-RDP-02 — MUST.** Validate RDP server certificate against broker-supplied fingerprint/internal CA policy.
  - *Acceptance:* Positive pin and negative mismatch/untrusted tests.
- **FR-RDP-03 — MUST.** Render the RDP session in a MobiDesk-owned native Activity; Compose must not decode and re-render desktop frames.
  - *Acceptance:* Architecture/code review and physical UI test.
- **FR-RDP-04 — MUST.** Implement a render-target abstraction and complete the pinned FreeRDP `MS-RDPEDISP` / surface attach-detach spike before R1 architecture freeze.
  - *Acceptance:* Recorded pinned-source spike, resize/surface tests and explicit R2 migration-or-reconnect decision.
- **FR-RDP-05 — MUST.** Prove that the native FreeRDP transport is a protected local stream bridged to MobiDesk raw-WSS relay; do not confuse RD Gateway WebSocket transport with raw WSS.
  - *Acceptance:* Pinned-source API review; byte-for-byte loopback/WSS echo test; no direct RDP-to-public or unauthenticated localhost path.

Touch, pointer and keyboard input

- **FR-INPUT-01 — MUST.** Provide a default trackpad model: one-finger move = relative pointer; tap = left click; long-press then drag = left-button drag; two-finger drag = scroll; two-finger tap = right click.

  - *Acceptance:* Manual interaction checklist on reference phone.
- **FR-INPUT-02** — **MUST.** Provide soft keyboard and native shortcut controls for Ctrl, Alt, Shift, Win, Esc, Tab, Delete, arrows and keyboard show/hide; send Ctrl+Alt+Delete through the supported FreeRDP API.
  - *Acceptance:* Verify text entry and every listed shortcut in Windows.
- **FR-INPUT-03** — **MUST.** Keep the active RDP screen and task-switcher preview protected by Android `FLAG_SECURE` by default.
  - *Acceptance:* Screenshot/recents test on RD-1.

Lifecycle and cleanup

- **FR-LIFE-01** — **MUST.** Rotate, foreground/background, network loss, cancellation and process death must not leave an orphaned session. No fixed background-duration guarantee is made.
  - *Acceptance:* Lifecycle fault-injection tests.
- **FR-LIFE-02** — **MUST.** Reconnect uses a new grant and revalidates assignment/status; no expired grant is reused.
  - *Acceptance:* WSS drop/reconnect integration test.
- **FR-LIFE-03** — **MUST.** Disconnect immediately blocks input and releases native client, local transport, WebSocket and broker session.
  - *Acceptance:* Ten-cycle leak/cleanup test and broker slot inspection.
- **FR-LIFE-04** — **MUST.** R1 session is foreground-only; if the app remains stopped/backgrounded or screen-locked for 5 seconds, it tears down and requires a fresh grant on resume.
  - *Acceptance:* Activity lifecycle instrumentation test on RD-1; verify no RDP socket, native worker or broker slot remains.

Telemetry and diagnostics

- **FR-OBS-01** — **MUST.** Emit privacy-safe stage timings and error codes for session attempts, including broker status, guest credential submission, grant, WSS, RDP negotiation, NLA, first frame, FPS windows, input latency and cleanup.
  - *Acceptance:* Telemetry schema validation and secret/PII scan.

Device and application security

- **FR-SEC-04** — **MUST.** Treat a high-confidence rooted/unlocked-bootloader signal as unsupported and block the Cloud PC session; record unknown integrity as `UNKNOWN`, not `CLEAN`.
  - *Acceptance:* Device-policy test plus explicit limitations record.

Release integrity

- **FR-REL-01** — **MUST.** Produce a reproducible release artifact signed with the correct owner-controlled key/upload key.

  - *Acceptance:* `apksigner`/bundle verification, certificate record and exact artifact hash.
- **FR-REL-02 — MUST.** Release artifact contains no demo mode, mock assignment fallback, trust-all certificate policy, cleartext traffic or test endpoint.
  - *Acceptance:* Automated release configuration checks and manual APK inspection.

Dock pairing and display (R2)

- **FR-DOCK-01 — R2.** Pair only with an authenticated dock using explicit user approval and cryptographic challenge-response.
  - *Acceptance:* Spoofed AOA device is rejected; paired dock authenticates.
- **FR-DOCK-02 — R2.** Display target can be attached/detached without confusing the broker session lifecycle; resolution behavior is specified and tested.
  - *Acceptance:* RDPEDISP / reconnect spike and dock integration evidence.

8. Non-functional requirements and pilot performance gates

All performance values below are **R1 pilot acceptance targets**, not claims about current performance. They must be measured on the nominated reference phone, a known VM and a controlled 5 GHz Wi-Fi baseline. Record the actual network RTT and test conditions. Do not compare results from uncontrolled networks as if they were equivalent.

- **NFR-PERF-01 — Time to first desktop frame. Gate:** p90 <= 20 seconds over at least 20 controlled connection attempts. **Measurement:** Monotonic timestamp from Windows credential submission to first valid desktop frame; separately report human time from Connect tap to credential submission.
- **NFR-PERF-02 — Rendering rate. Gate:** Average >= 15 presented FPS during a 120-second 1280x720 motion workload; report p50/p90 and dropped frames. **Measurement:** Native FreeRDP graphics callback/present counter.
- **NFR-PERF-03 — Input response. Gate:** p90 <= 250 ms on reference Wi-Fi when baseline network RTT is <= 40 ms. **Measurement:** Scripted pointer/key action to visible response, using a test workload and monotonic timestamps.
- **NFR-PERF-04 — First-attempt reliability. Gate:** At least 19 of 20 controlled connection attempts succeed on first try; all failures have a stage-specific error. **Measurement:** Attempt-level ledger, not percentage of four pilot students.

- **NFR-PERF-05 — Cleanup stability. Gate:** 20 connect/disconnect cycles with zero native crash and zero leaked broker session slots or local sockets. **Measurement:** Crash logs, process inspection and broker slot counters.
- **NFR-PERF-06 — Recovery. Gate:** A short Wi-Fi interruption (<= 10 seconds) recovers within 15 seconds when VM remains available; reconnect must request a new grant. **Measurement:** Network fault injection with stage timestamps.
- **NFR-SEC-01 — Unauthorized access. Gate:** Zero successful unauthorized connections across all negative authorization tests. **Measurement:** Automated broker and physical-device tamper suite.
- **NFR-PRIV-01 — Sensitive data. Gate:** Zero credentials, grants, JWTs, private VM endpoints or screen contents in logs/telemetry. **Measurement:** Static secret scan, log scan and packet inspection.
- **NFR-COMP-01 — Android build. Gate:** Preserve the target repository's verified min/compile/target SDK and ABI baseline unless an approved change is recorded. **Measurement:** Gradle configuration and APK Analyzer.

8.1 Reference device and platform baseline

- **Reference device RD-1:** Google Pixel 6, Android 16 / API 36, arm64 physical device. This is a nominated test target, not a claim that a physical unit has already been tested. Confirm the actual hardware/build before the G4 performance gate; an emulator is not a substitute for the physical R1 gate.
- **Minimum Android:** R1 supports Android API 29 or newer unless the owner approves a product-scope change.
- **Target/compile SDK:** use the latest stable SDK supported by the pinned build toolchain and verified by tests. Do not lower the target API to avoid platform behavior changes. If Google Play distribution is selected, the release must target API 36 or higher under the policy effective from 31 August 2026.
- **Native ABIs:** `arm64-v8a` is mandatory for physical pilot/release devices. `x86_64` is retained for emulator and development validation where supported by the pinned native build.
- **FreeRDP:** use the repository-pinned FreeRDP v3.32.0 revision until a reviewed compatibility/security change is approved.

The exact SDK/Gradle/ABI values observed in the last repository audit are historical implementation facts in `BASELINE_AUDIT.md`, not permanent product requirements. See `OPERATIONS.md` for the private pilot and Play App Signing distinction.

8.2 Background behavior

R1 pilot default: the interactive RDP session is foreground-only. MobiDesk does not start a foreground service merely to keep the Wi-Fi RDP/WSS socket alive. When `RdpSessionActivity` enters a true stopped/background state or the screen is locked, it starts a five-second cancelable teardown window. If the Activity does not resume within that window, the client disconnects FreeRDP, WSS and the local bridge, clears transient credentials and closes the broker session; returning to MobiDesk requires a fresh status check, Windows credential prompt and grant. Configuration changes, rotation and the soft keyboard must not be mistaken for backgrounding. This avoids promising an unsupported service type for a Wi-Fi-only R1 session. R2's USB-attached dock lifecycle is a separate design and must independently satisfy the exact Android foreground-service type, permission and runtime prerequisites before any long-running service is enabled.

9. Privacy, security and trust requirements

1. The client sends only the signed-in user's current Supabase access token to broker HTTPS endpoints. No service-role/secret key is included in the APK.
2. Broker identity is derived from a verified JWT (`iss`, `aud`, `exp`, signature, subject and `session_id`). Never trust email or client metadata as an admin role.
3. The broker checks that the token's Supabase session remains active at grant issuance. During a relay, it rechecks active session and assignment state at least every 15 seconds and closes within 30 seconds after revocation. Supabase access JWTs may remain valid until expiry after sign-out; validation of the `session_id` against active session state is therefore required for this sensitive operation.
4. Session grants contain at least 256 bits of unpredictable entropy, are stored server-side as a hash, expire in 60 seconds, are single-use and are bound to the authenticated user/session and server-resolved VM. Rate-limit grant requests to 5 per minute per user for the pilot; tune only from measured need.
5. Broker listener binds to loopback only. The WSS proxy is separately authenticated, and only the broker can connect to private VM TCP/3389. Public 3389, arbitrary TCP forwarding and public VM IPs are prohibited.
6. Local FreeRDP transport must be protected from local socket hijack. Prefer a socketpair/connected descriptor. Otherwise use a local socket with same-UID peer verification. Do not ship an unauthenticated TCP localhost bridge.
7. RDP server certificate pin mismatch or missing certificate policy blocks connection. No accept-all toggle in release.
8. Tokens and credentials are never written to disk, Logcat, crash reports, analytics or URL query parameters. Grant is never persisted or placed in

a deep link/URI.

9. Apply `FLAG_SECURE` to the RDP session Activity by default for the pilot. Screenshots/recording are disabled unless the project owner and lab policy explicitly approve a controlled exception.
10. Rooted-device policy: R1 treats a high-confidence rooted or unlocked-bootloader signal as unsupported and blocks the Cloud PC session. If the platform cannot provide a reliable result, record `UNKNOWN`; do not report the device as clean. The pilot only accepts owner-approved test devices, and local integrity checks are defense-in-depth rather than the authorization boundary.
11. Use TLS 1.2 or newer for HTTPS/WSS. Release builds block cleartext traffic and disallow trust-all certificate managers.
12. Audit grant issuance, denial, relay open/close and revocation using opaque IDs and error codes, not passwords, bearer tokens or private endpoint data.
13. Windows guest credential abuse: Lab IT MUST confirm a Windows account lockout/failed-logon monitoring policy suitable for the pilot. The client MUST rate-limit repeated guest-auth retries locally and must not reveal whether a username exists. Since the broker is an encrypted byte relay and cannot inspect NLA credentials, Windows account lockout and event auditing remain guest/administrator responsibilities; the broker's grant rate limit is not a substitute.
14. Before R1 release, review the exact pinned FreeRDP revision against maintained security advisories. No unreviewed high/critical applicable advisory may remain open. An upgrade is performed only as a reviewed source/dependency change with build, ABI, protocol and regression tests; this documentation change does not silently move the submodule.

See `SECURITY_THREAT_MODEL.md` for trust boundaries, attacks and required tests.

10. VM, identity and data lifecycle

- R1 is Windows-only and one VM per student. An assignment must be unique. If the data model returns zero or more than one active assignment, fail closed; do not choose the first row.
- The broker must route only to the current owner-approved subset of real, verified VM mappings and deny any assignment without a verified map. The dated baseline audit records which endpoints were last verified; recheck before testing/deployment. Do not add placeholder addresses or silently move a student to another VM.
- **Product behavior:** R1 does not erase, reset or re-image a guest automatically. An administrator must approve destructive repair/reset and take a backup/snapshot first.
- **Infrastructure fact:** whether the current VM disks persist across host restart/recreation, which storage pool holds them, and whether backups

exist are not established by the available project evidence. Verify before any student pilot that could hold coursework.
- Production deployment requires a documented backup cadence, restore drill, student-data retention period, semester-end archive/delete policy and owner for account/VM offboarding. These policies are not currently evidenced and are G5 blockers for broader deployment.
- The last audit described self-hosted KVM/libvirt on `mobilab-server`; the final hosting location, campus network path, internet ingress, power/backup arrangements and ongoing operating cost remain to be confirmed. Do not infer geographic locality or availability from the hostname.
- No in-app VM power controls are included in R1. A VM that is stopped/unavailable presents its state and an administrator contact path.

11. Product success measures

The pilot is small; adoption percentages and market-scale conversion rates are not meaningful. R1 success is measured using test-attempt and control evidence:

- Exact authorized mapping: each test account sees only its own assignment; no cross-account mapping or session succeeds.
- Session completion: report raw counts and stage failures across at least 20 controlled attempts and the four currently verified endpoints.
- Performance: NFR-PERF-01 through NFR-PERF-06 pass on RD-1 and the controlled Wi-Fi baseline.
- Security: zero successful unauthorized connections; zero leaked credentials/tokens/endpoints.
- Stability: 20 connect/disconnect cycles without native crash or orphaned resources.
- Support readiness: every error class maps to a user-readable message and an operator diagnostic code.
- R2 readiness: architecture spike produces a measured recommendation, not an assumed transcoding topology.

12. User-facing error catalogue

- `AUTH-01` — **Identity.** "Your sign-in session expired. Sign in again." *Retry:* Re-authenticate.
- `ASSIGN-01` — **Assignment.** "No Cloud PC is assigned to your account. Contact the lab administrator." *Retry:* No retry until assignment changes.
- `ASSIGN-02` — **Assignment.** "We could not verify your assigned Cloud PC. Try again." *Retry:* User retry with bounded backoff.
- `ASSIGN-03` — **Assignment.** "Your Cloud PC assignment needs administrator review." *Retry:* No retry.
- `VM-01` — **Lifecycle.** "Your Cloud PC is powered off. Contact the lab administrator." *Retry:* Later; no client power control.

- `VM-02` — **Readiness.** "Your Cloud PC is starting or is not ready yet." *Retry:* Retry status after backoff.
- `VM-03` — **Readiness.** "Your Cloud PC cannot be reached right now." *Retry:* Retry status; no automatic grant.
- `GRANT-01` — **Broker.** "We could not authorize a session. Try again." *Retry:* Fresh request only.
- `GRANT-02` — **Broker.** "This session request expired. Try connecting again." *Retry:* Fresh request only.
- `TUNNEL-01` — **WSS.** "The secure connection service could not be reached." *Retry:* Bounded retry, fresh grant.
- `RDP-CERT-01` — **RDP TLS.** "The Cloud PC security certificate could not be verified. Connection blocked." *Retry:* No override; administrator action.
- `RDP-AUTH-01` — **NLA.** "Windows sign-in failed. Check your separate lab credentials." *Retry:* User may retry with fresh grant.
- `RDP-01` — **RDP.** "The Cloud PC could not complete the remote desktop connection." *Retry:* Retry after status check.
- `SESSION-01` — **Active.** "Connection lost. Reconnecting securely…" *Retry:* New grant, bounded retry.
- `SESSION-02` — **Active.** "Your session was ended by the administrator or access policy." *Retry:* No retry until access revalidated.
- `SESSION-03` — **Cleanup.** "The session did not close cleanly. Reopen only after cleanup is verified." *Retry:* Block duplicate session while orphan cleanup runs.

All messages must be mapped to tests. Do not surface hostnames, IPs, stack traces or raw backend errors to students.

13. Release gates

- **G0 — Product/baseline freeze.** Owner approves this PRD; target repository branch/commit and FreeRDP gitlink are rechecked; source conflict list is recorded.
- **G1 — Contract and threat-model freeze.** No-client-VM-ID grant contract, status endpoint, active-session check, guest-auth flow, RDP pin policy and local bridge security are implemented in design/API tests.
- **G2 — Broker ready.** Broker passes auth/assignment/replay/revocation/allowlist tests; four currently approved endpoints are explicitly mapped; status endpoint works; stable WSS route and loopback-only binding verified.
- **G3 — Android session ready.** Compose UI, native RDP Activity, Windows credential prompt, pinned FreeRDP, certificate callback and secure local bridge pass unit/instrumented tests.
- **G4 — Physical R1 acceptance.** Correct assigned VM opens on RD-1; cross-user/expired/replay/revocation tests pass; p90 first-frame, FPS, input-latency, recovery and cleanup targets in NFR-PERF-01 through NFR-PERF-06 pass on the defined network baseline; 20-cycle cleanup

passes. No performance metric may be waived by a successful build.
- **G5 — Release and operations ready.** Exact release artifact signed, certificate/hash/source revision recorded; distribution route decided; support, backup, restore, retention and rollback documents approved.

A gate is not passed by a build status alone. Each gate must link to evidence in `PROGRESS.md` or a test report.

14. Ownership and dates

The Project Owner is the single accountable approver for product and release decisions. The same person may perform engineering/QA tasks with AI assistance; do not invent separate leads for a one-person project. College/lab IT is a consulted dependency for Windows account and data-retention policy.

- **Approve PRD and architecture decisions.** Owner: Project Owner. Target: 4 Nov 2026. Status: Pending approval.
- **Freeze exact target repository branch/commit and doc baseline.** Owner: Project Owner. Target: 4 Nov 2026. Status: Pending live GitHub access/recheck.
- **Confirm Windows pilot account provisioning and reset process.** Owner: Project Owner + Lab IT. Target: 5 Nov 2026. Status: Pending.
- **Approve broker session-active lookup path and status probe.** Owner: Project Owner. Target: 6 Nov 2026. Status: Pending implementation design review.
- **Approve stable WSS hostname/route.** Owner: Project Owner. Target: 6 Nov 2026. Status: Pending.
- **Complete broker API/authorization changes.** Owner: Project Owner / implementation agent. Target: 8 Nov 2026. Status: Not started.
- **Complete native FreeRDP session integration.** Owner: Project Owner / implementation agent. Target: 10 Nov 2026. Status: Not started.
- **Physical R1 performance/security acceptance.** Owner: Project Owner / test participants. Target: 12 Nov 2026. Status: Not started.
- **Approve release signing and pilot distribution.** Owner: Project Owner. Target: 13 Nov 2026. Status: Pending.

Dates are planning targets, not evidence of completed work. Reforecast on dependency failure and preserve the reason in `TASKS.md`.

15. Risks

- **Windows guest account path not provisioned.** Impact: NLA cannot complete; R1 blocked Mitigation / owner: Separate per-student guest accounts and secure per-session prompt; Project Owner + Lab IT.
- **Broker prototype API differs from target contract.** Impact: Client/backend mismatch Mitigation / owner: Version contract first; remove client VM identifier and add status/session revocation checks

before integration.

- **VM4 endpoint/OS remains unverified.** Impact: One assigned test account cannot connect Mitigation / owner: Keep VM4 excluded; fail closed for missing map; do not reassign.
- **Stable WSS endpoint unavailable.** Impact: Mobile device cannot reach broker Mitigation / owner: Choose owner-controlled domain/route and test WSS upgrade/idle behavior before client release.
- **Broker enumeration or connection-exhaustion attack.** Impact: Assignment/VM metadata may leak or pilot capacity may be exhausted Mitigation / owner: Return no VM identifiers/endpoints; generic denial codes; rate-limit status/grant requests; cap sessions, frame size, queues and connection lifetime; alert on repeated denials.
- **RDP certificate pin not provisioned.** Impact: Cannot verify end-to-end RDP TLS Mitigation / owner: Create verified per-VM fingerprint/CA inventory and rotation process.
- **FreeRDP bridge API cannot support protected local transport.** Impact: Potential local hijack or substantial integration delay Mitigation / owner: Spike pinned v3.32.0 descriptor/socket support; block insecure loopback fallback.
- **Native Activity/display coupling blocks R2.** Impact: Dock architecture rework Mitigation / owner: Keep render/session abstraction in R1; test RDPEDISP support early; benchmark Pi-native vs phone transcode.
- **Foreground-service behavior is assumed.** Impact: Android background crash/termination or policy rejection Mitigation / owner: Do not promise fixed background duration; test exact target SDK and permitted FGS type; reconnect gracefully.
- **Reference phone unavailable.** Impact: Performance gate cannot be trusted Mitigation / owner: Confirm Pixel 6/API 36 physical RD-1 or record an approved replacement before G4.
- **Data persistence/retention/backup undefined.** Impact: Student work loss or unmanaged sensitive data Mitigation / owner: Define backup, restore and semester-end lifecycle before broader deployment.

16. Normative references

- Supabase user sessions and the JWT `session_id` claim: https://supabase.com/docs/guides/auth/sessions
- Supabase sign-out behavior and the fact that an issued access-token JWT remains valid until expiry unless the server checks session state: https://supabase.com/docs/reference/javascript/auth-signout
- Android foreground service types, permissions and runtime prerequisites: https://developer.android.com/develop/background-work/services/fgs/service-types
- Google Play target API requirements (from 31 August 2026, new apps and updates require API 36 or higher): https://support.google.com/googleplay/android-developer/answer/11926878
- Play App Signing: https://support.google.com/googleplay/android-

developer/answer/9842756

- Android app signing: https://developer.android.com/studio/publish/app-signing
- Pinned FreeRDP source/build documentation: use the checked-in FreeRDP v3.32.0 gitlink/submodule in this repository, not current upstream `master` as an implementation reference.

17. Change control

This PRD becomes the normative product specification after Project Owner approval. A requirement change must record the reason, affected journey/requirement IDs, architecture/API/security impact, tests to update, accountable owner and effective date. Prototype code, a test passing under a different behavior, or a build constraint cannot silently change a requirement. The baseline audit and review findings are maintained separately. Open dependencies and approval dates live in `OPEN_ITEMS.md` and `TASKS.md`.